Dokumentacja końcowa

Sposób uruchomienia programu:

Najpierw otwieramy zaporę sieciową windows i dodajemy port 1883 oraz 5000 jako wyjątek. Następnie odpalamy konsolę cmd i wpisujemy komendę ”mosquitto -v”. Następnie odpalamy plik virtual.py oraz app.py za pomocą visual studio, najlepiej w osobnych oknach.

Przed otworzeniem app.py trzeba podać w kodzie ścieżkę do certyfikatów, w folderze, w którym się znajdują, w naszym przypadku wygląda to tak:

```
app.run(host='0.0.0.0', port=5000, debug=True,
ssl_context=('c:/Users/2020/Desktop/Bemsi projekt/certyfikaty/server.crt',
'c:/Users/2020/Desktop/Bemsi projekt/certyfikaty/ca.key'))
```

Gdyby serwer miał problem z certyfikatami wystarczy zmienić kod na:

```
app.run(host='0.0.0.0', port=5000, debug=True)
```

Program uruchomi się wtedy bez certyfikatów.

Broker oraz dwa pliki muszą chodzić w tle, aby program poprawnie działał. Serwer chodzi można z niego korzystać.

Użyte Narzędzia:

- Broker mqtt mosquitto odpalony przez konsolę cmd
- Visual studio
- Biblioteki pythona takie jak flask,flask_login, paho.mqtt.client, binascii
- Program openSSL do generowania certyfikatu za pomocą konsoli cmd

Analiza Ryzyka

Nasz program ma 4 zabezpieczenia:

1. Hashowanie z solą haseł
2. Co najmniej 12 znakowe hasło
3. Certyfikat SSL
4. Szyfrowane połączenie brokera z serwerem.

Zabezpieczenia chronią przed następującymi atakami:

1) Hashowanie z solą haseł

- **Ataki typu brute force** : Hashowanie haseł, zwłaszcza w połączeniu z techniką solenia (dodawania losowego ciągu do hasła przed hashowaniem), utrudnia ataki typu **brute force**. W takim ataku, atakujący próbuje zgadnąć hasło poprzez systematyczne próbowanie wszystkich możliwych kombinacji.
- **Ataki słownikowe**: Hashowanie haseł chroni również przed atakami słownikowymi, w których atakujący używa predefiniowanej listy haseł (często używanych lub łatwych do zgadnięcia) próbując odkryć każde z nich, aby znaleźć pasujące. Tak jak w przypadku ataków brute force, solenie w połączeniu z hashowaniem może skutecznie utrudnić tego typu ataki.
- **Duplikacja haseł**: Bez hashowania, jeśli kilka kont używa tego samego hasła to łatwo można włamać się do kilku kont mając jedno hasło, co to oczywiste w bazie danych. Z hashowanymi hasłami, nawet jeśli dwa hasła są takie same, ich hashe będą różne co utrudnia odkrycie tego faktu przez potencjalnego napastnika.

2) Co najmniej 12 znakowe hasło

- Chroni nas przed atakiem typu Brute force i atakiem słownikowym, ponieważ liczba możliwych znaków na jeden znak hasła jest bardzo duża, przykładowo:

  Wielkie litery: od A do Z (26 znaków)

  Małe litery: od a do z (26 znaków)

  Cyfry: od 0 do 9 (10 znaków)

  Symbole: (spacja) ! " # $ % & ' ( ) * + , - . / : ; < = > ? @ [\ ] ^ _` { | } ~ (33 znaki)

  Sumując wszystkie możliwe znaki otrzymamy 95 możliwości co daje nam co najmniej $95^{12} \approx 5{,}4 \cdot 10^{23}$ kombinacji.

3) Certyfikaty SSL:

- **Słuchanie podsłuchowe**: Certyfikaty SSL zapewniają szyfrowanie, co oznacza, że informacje przesyłane między klientem a serwerem są zaszyfrowane i nie mogą być odczytane przez kogoś, kto przechwycił te dane. To zapobiega podsłuchiwaniu i kradzieży informacji.

- **Ataki typu "man-in-the-middle" (MitM)**: Certyfikaty SSL zapewniają uwierzytelnianie, co oznacza, że strony komunikujące się ze sobą mogą potwierdzić swoją tożsamość. Dzięki temu możemy mieć pewność, że komunikujemy się z prawdziwym serwerem, a nie z atakującym, który próbuje podszyć się pod niego.
- **Zmiana danych**: Ponieważ dane są szyfrowane, atakujący nie może zmienić danych przesyłanych między klientem a serwerem bez wywołania błędów, które zostaną wykryte przez obie strony.
- **Poufność i integralność danych**: Certyfikaty SSL chronią prywatność i integralność danych przesyłanych między klientem a serwerem. Wszelkie próby przechwycenia lub zmiany tych danych mogą być wykryte.
- **Zaufanie**: Certyfikaty SSL są wydawane przez zaufane trzecie strony, zwane Organizacjami Certyfikacyjnymi (CA). Kiedy strona internetowa ma certyfikat SSL od renomowanej CA, użytkownicy mogą zaufać tej stronie, wiedząc, że ich dane są bezpieczne.
- Ostatecznie, certyfikaty SSL są istotnym elementem bezpieczeństwa sieciowego i prywatności, chroniąc strony internetowe i ich użytkowników przed różnymi rodzajami ataków i wykorzystaniem nieautoryzowanych informacji.

4) Szyfrowane połączenie brokera z serwerem:

- TLS zapewnia zarówno autentyczną wymianę danych między serwerem a klientem, jak i ochronę przesyłanych danych przed podsłuchem i manipulacją.